lab 2: social Engineering Lab

Lab Overview

Title: Social Engineering Toolkit (SET) and Reconnaissance Lab

Duration: 2-3 hours

Difficulty Level: Intermediate

Prerequisites

- Completed Day 1 lab (Shodan and Google Dorking)
- Basic understanding of Linux command line
- VMware Workstation installed
- Understanding of social engineering concepts from Day 2 lecture

Lab Environment

- Host Machine: Windows 11 (25H2) with VMware Workstation
- Virtual Machine: Kali Linux (latest version)
- Network Configuration: NAT (Network Address Translation)
- Tools Used: Social Engineering Toolkit (SET), Zphisher, GoPhish, Maltego CE, Sherlock

Learning Objectives

By the end of this lab, I am able to:

Understand Social Engineering Attack Vectors

- Recognize how phishing campaigns are crafted and deployed
- Identify the technical components of credential harvesting attacks
- Understand the psychology behind effective social engineering tactics

Deploy Phishing Infrastructure

- Set up and configure the Social Engineering Toolkit (SET)

- Create convincing fake login pages using multiple tools
- Host phishing pages on local web servers
- Understand how attackers clone legitimate websites

Perform OSINT Reconnaissance

- Use Maltego for visual relationship mapping
- Employ Sherlock for username enumeration across platforms
- Gather intelligence on fictional targets
- Understand the reconnaissance phase of social engineering attacks

Analyze Attack Effectiveness

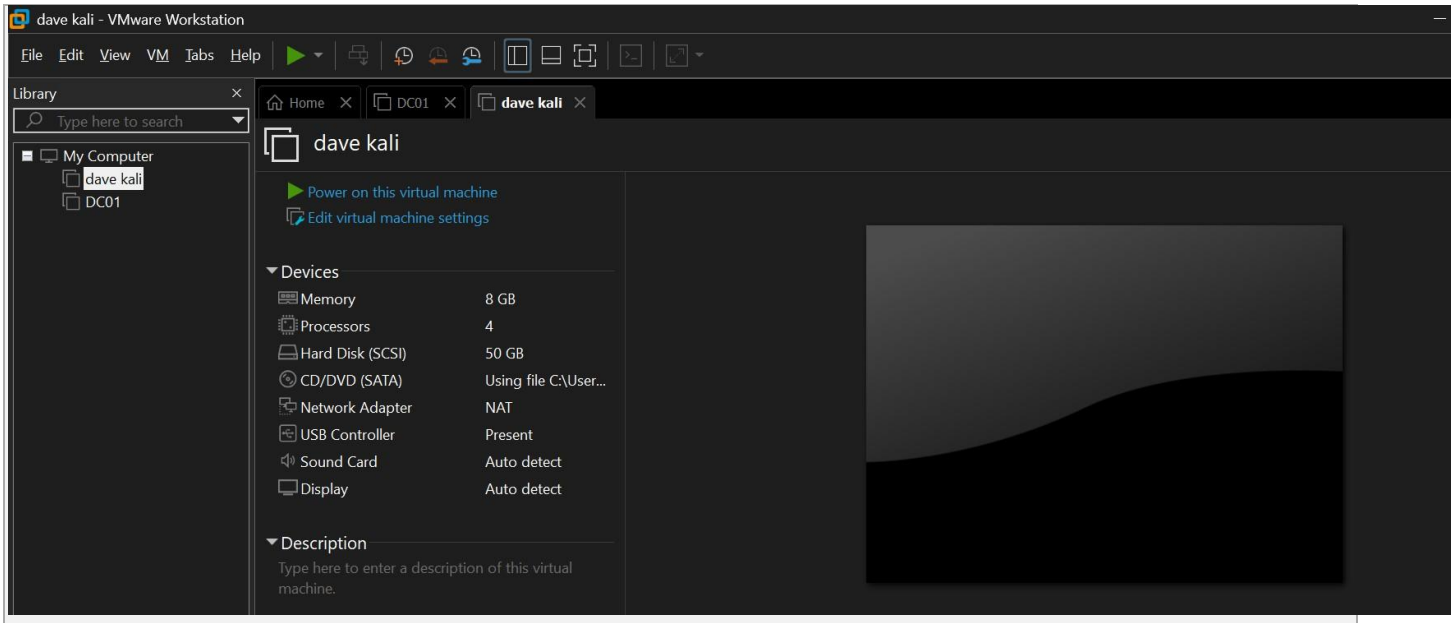
- Capture credentials from simulated phishing attacks
- Review log files and captured data
- Identify indicators of compromise
- Understand defensive countermeasures

Apply Ethical Boundaries

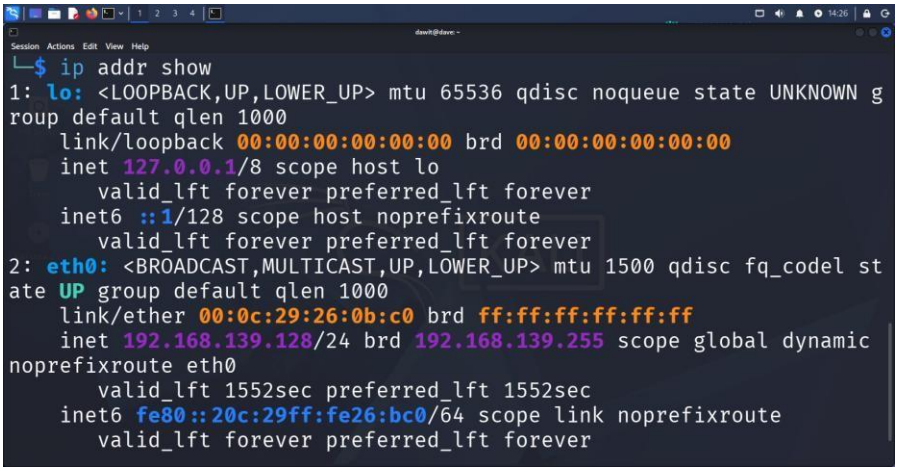
- Practice social engineering techniques in a controlled environment
- Understand legal and ethical implications
- Recognize the importance of authorization in security testing

Lab Setup Documentation

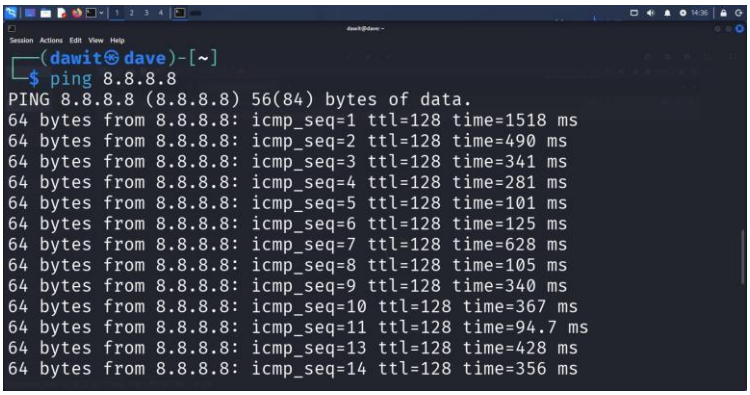
The Kali Linux VM was configured in VMware Workstation following the steps outlined in the lab guide: downloading the official Kali Linux ISO, creating a new virtual machine (Linux / Debian 13.x 64-bit), allocating 4 CPU cores and 4GB RAM, a 50GB single-file virtual disk, and a NAT network adapter. The graphical installer was used with English (United States) locale, hostname "kali", guided LVM partitioning across the entire disk, and the Xfce desktop environment with the default top10/default tool collections. GRUB was installed to /dev/sda as the primary boot device.



VM settings summary



Output of `ip addr show`



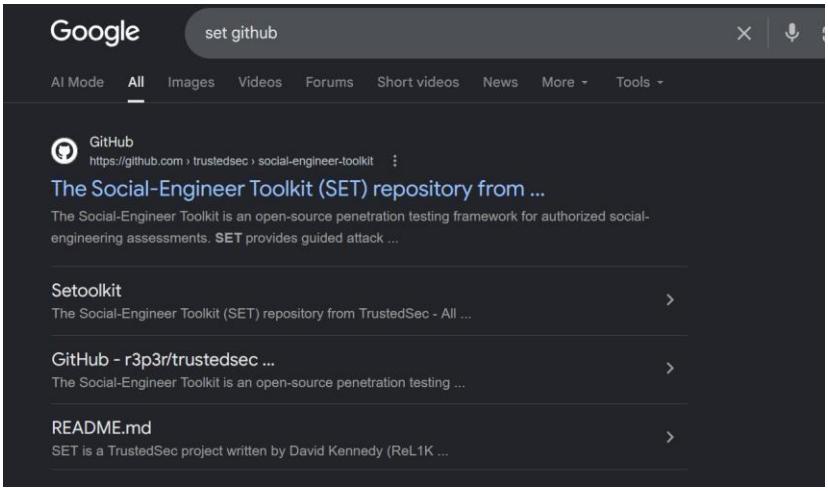
Output of `ping 8.8.8.8(confirming internet connectivity) Kali

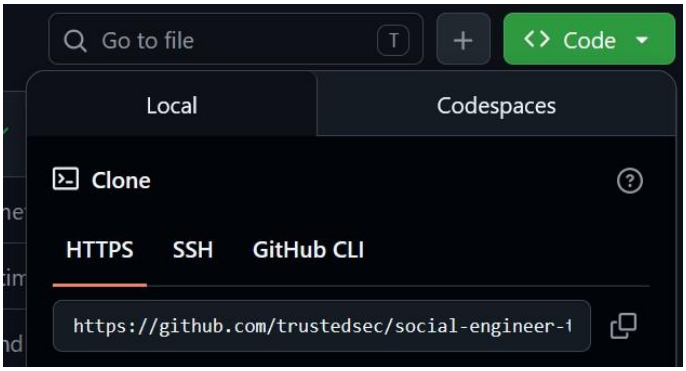
IP address recorded for this lab session:

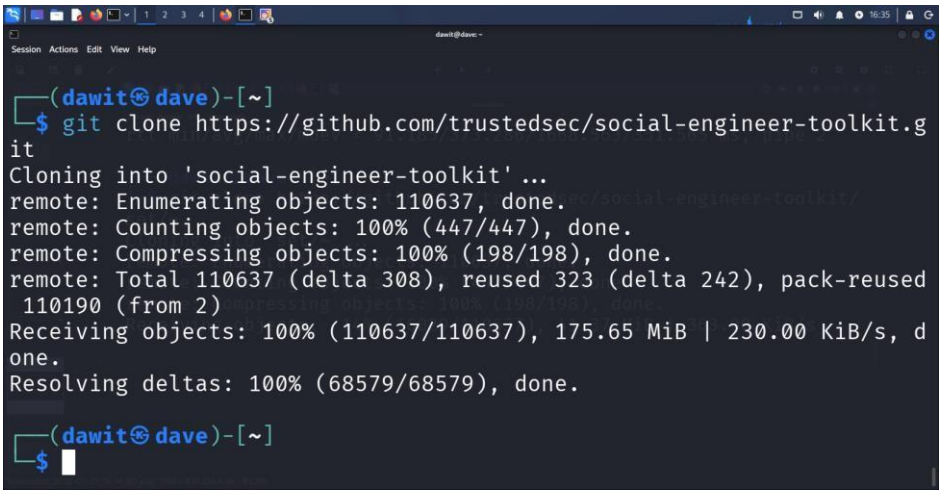
Kali VM IP Address: _____

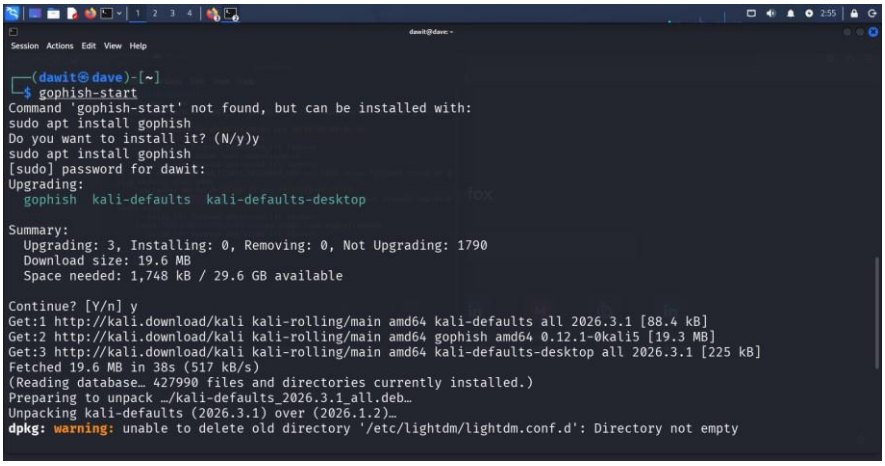
Tool Installation Verification

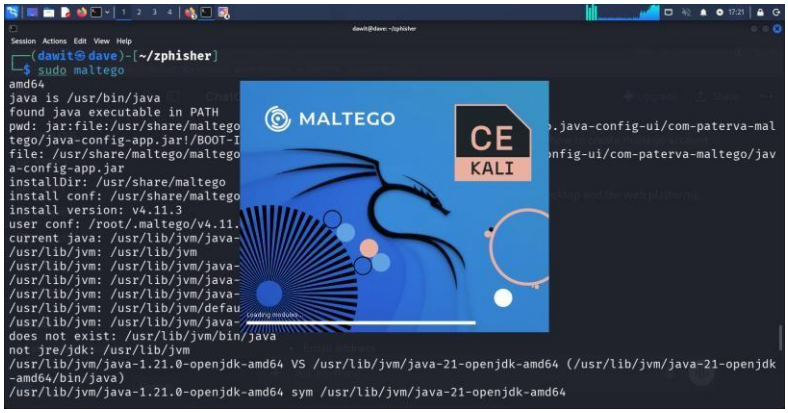
SET, Zphisher, GoPhish, Maltego CE, and Sherlock were installed per the lab guide (SET and Maltego pre-installed/updated via apt; Zphisher, GoPhish, and Sherlock cloned from GitHub).

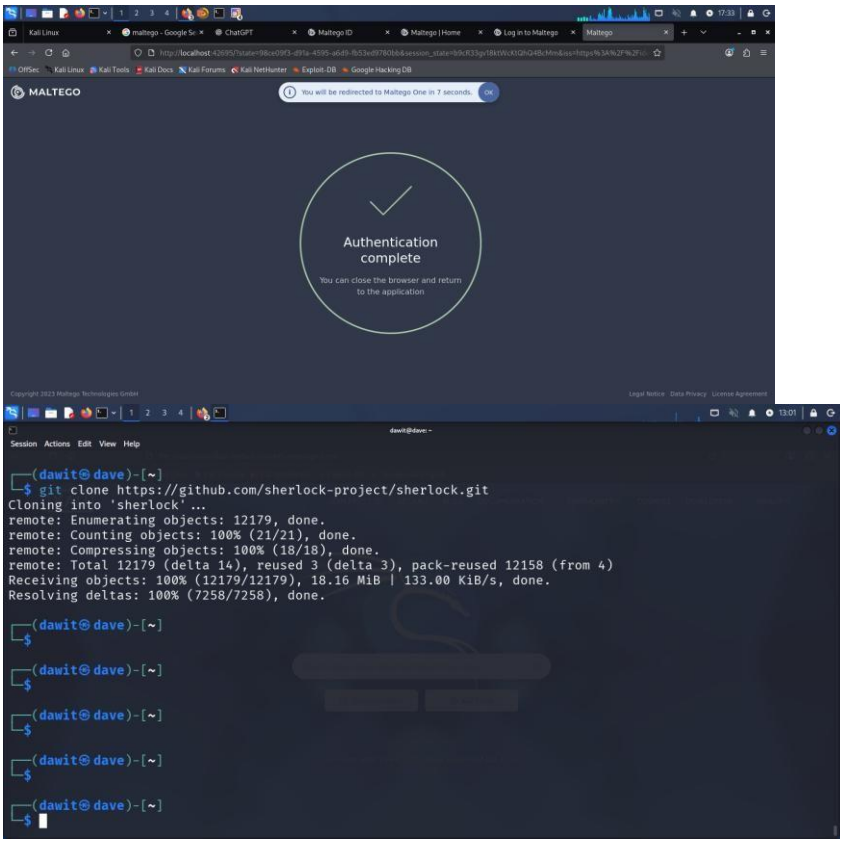





Session Actions Edit View Help
(dawit㉿dave)-[~]
$ git clone https://github.com/trustedsec/social-engineer-toolkit.git
Cloning into 'social-engineer-toolkit' ...
remote: Enumerating objects: 110637, done.
remote: Counting objects: 100% (447/447), done.
remote: Compressing objects: 100% (198/198), done.
remote: Total 110637 (delta 308), reused 323 (delta 242), pack-reused 110190 (from 2)
Receiving objects: 100% (110637/110637), 175.65 MiB | 230.00 KiB/s, done.
Resolving deltas: 100% (68579/68579), done.
(dawit㉿dave)-[~]
$

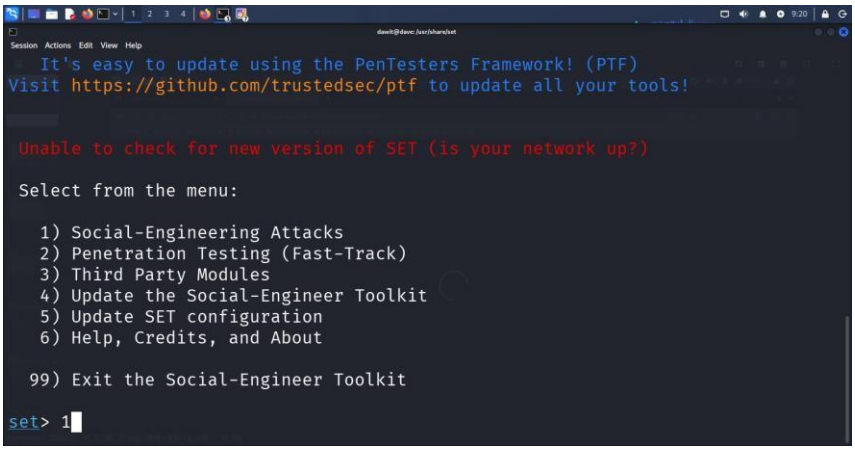

Session Actions Edit View Help
(dawit㉿dave)-[~]
$ gophish-start
Command 'gophish-start' not found, but can be installed with:
sudo apt install gophish
Do you want to install it? (N/y)y
sudo apt install gophish
[sudo] password for dawit:
Upgrading:
gophish kali-defaults kali-defaults-desktop
Summary:
Upgrading: 3, Installing: 0, Removing: 0, Not Upgrading: 1790
Download size: 19.6 MB
Space needed: 1,748 kB / 29.6 GB available
Continue? [Y/n] y
Get:1 http://kali.download/kali kali-rolling/main amd64 kali-defaults all 2026.3.1 [88.4 kB]
Get:2 http://kali.download/kali kali-rolling/main amd64 gophish amd64 0.12.1-0kali5 [19.3 MB]
Get:3 http://kali.download/kali kali-rolling/main amd64 kali-defaults-desktop all 2026.3.1 [225 kB]
Fetched 19.6 MB in 38s (517 kB/s)
(Reading database… 427990 files and directories currently installed.)
Preparing to unpack …/kali-defaults_2026.3.1_all.deb…
Unpacking kali-defaults (2026.3.1) over (2026.1.2)…
dpkg: warning: unable to delete old directory '/etc/lightdm/lightdm.conf.d': Directory not empty


Session Actions Edit View Help
(dawit㉿dave)-[~/zphisher]
$ sudo maltego
amd64
java is /usr/bin/java
found java executable in PATH
MALTEGO
CE
KALI
does not exist: /usr/lib/jvm/bin/java
not jre/jdk: /usr/lib/jvm
/usr/lib/jvm/java-1.21.0-openjdk-amd64 VS /usr/lib/jvm/java-21-openjdk-amd64 (/usr/lib/jvm/java-21-openjdk-amd64/bin/java)
/usr/lib/jvm/java-1.21.0-openjdk-amd64 sym /usr/lib/jvm/java-21-openjdk-amd64

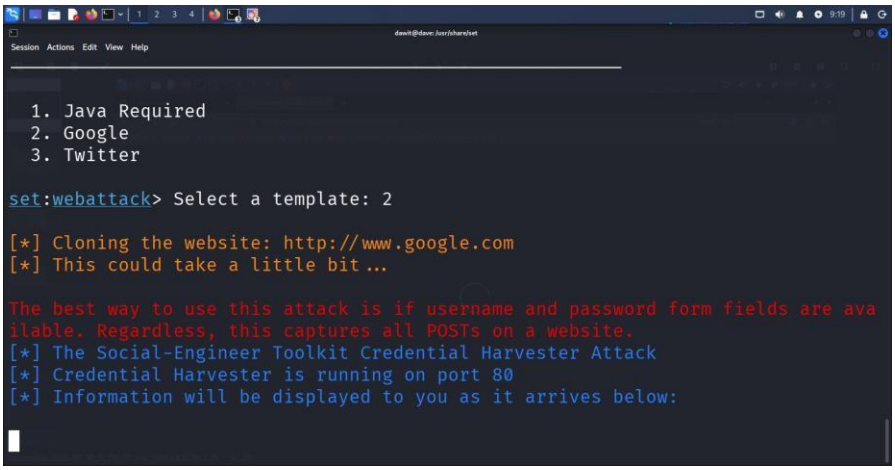


Exercise 1: Creating Phishing Pages with SET

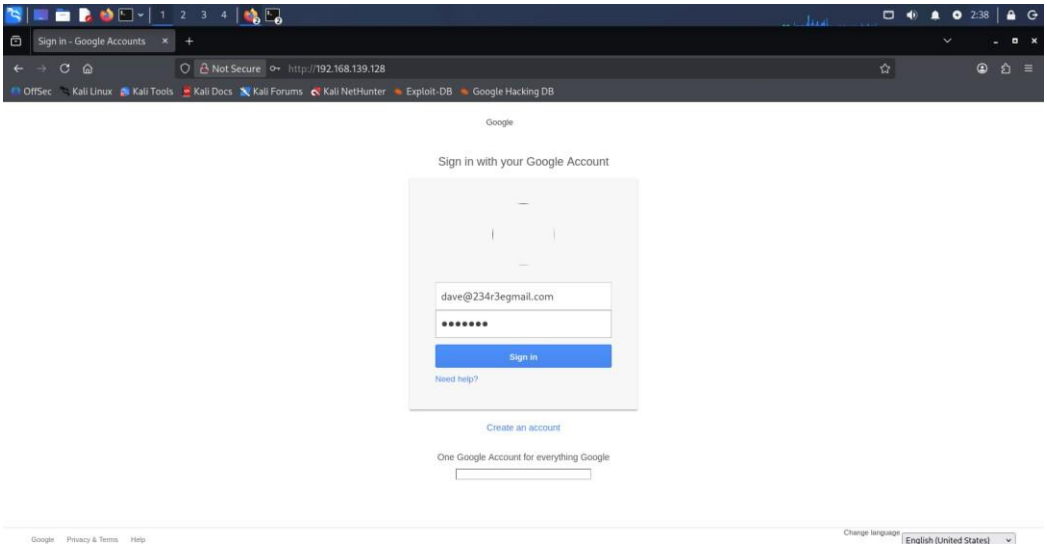
Objective: Create a fake login page to harvest credentials using Social Engineering Toolkit



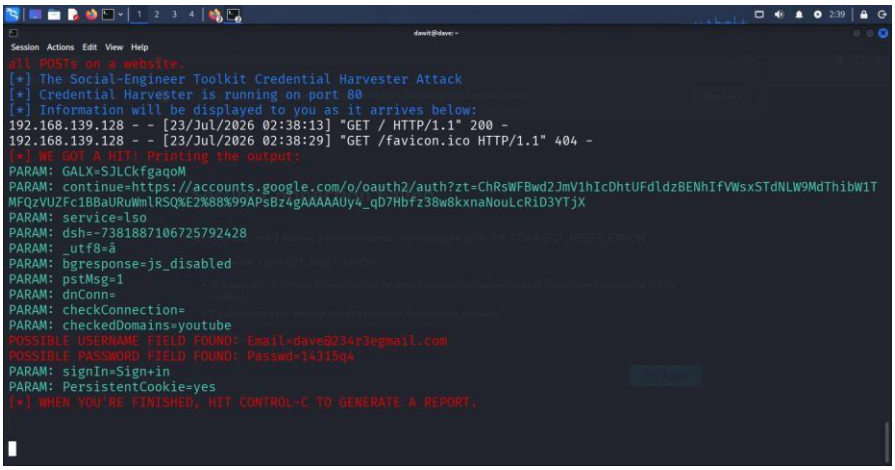
SET main menu



Selecting Social-Engineering Attacks > Website Attack Vectors > Credential Harvester



The cloned login page



: Captured credentials displayed in the SET terminal in real time

Questions to Consider

Q1. How difficult was it to create a convincing phishing page?

Creating the page itself was trivial — SET's Site Cloner automated the entire process of downloading and re-hosting the target site's HTML/CSS after only two prompts (listener IP and URL to clone). No manual HTML editing, scripting, or design work was required, which is the core lesson of this exercise: attackers do not need advanced webdevelopment skill to produce a visually convincing fake login page.

Q2. What visual indicators might alert a user this is fake?

- The URL bar shows a raw IP address (e.g., http://192.168.x.x) instead of the real domain name (e.g., accounts.google.com)
- The browser flags the connection as "Not Secure" because SET's default listener does not serve HTTPS/SSL
- No valid TLS certificate or padlock icon is present
- Minor rendering glitches can appear because dynamically loaded assets (some scripts, fonts, or backend features) are not captured by a simple site clone
- The page cannot complete a real login (e.g., no 2FA prompt, or it silently redirects after submission)

Q3. How could you make this attack more convincing?

- Register a look-alike domain (typosquatting, e.g., go0gle-secure.com) and route it to the phishing server
- Add a valid TLS certificate (e.g., via Let's Encrypt) so the browser shows HTTPS, as demonstrated later with Zphisher

- Send the link through a pretext (spoofed email, SMS, or QR code) built from OSINT-gathered details to increase perceived legitimacy
- Shorten or mask the URL, and host on a domain that resembles the target's actual domain structure
- Add urgency-based messaging ("your account will be suspended") to reduce the victim's scrutiny

Exercise 2: Advanced Phishing with Zphisher

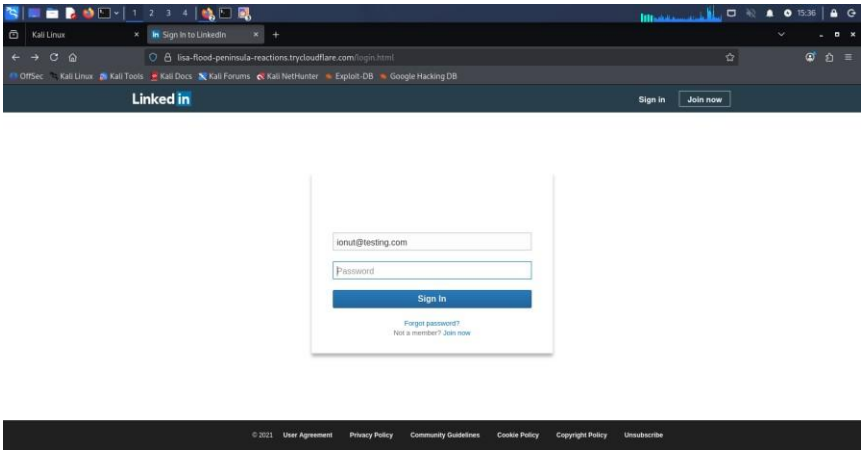
Objective: Use Zphisher to create multiple phishing templates with customization



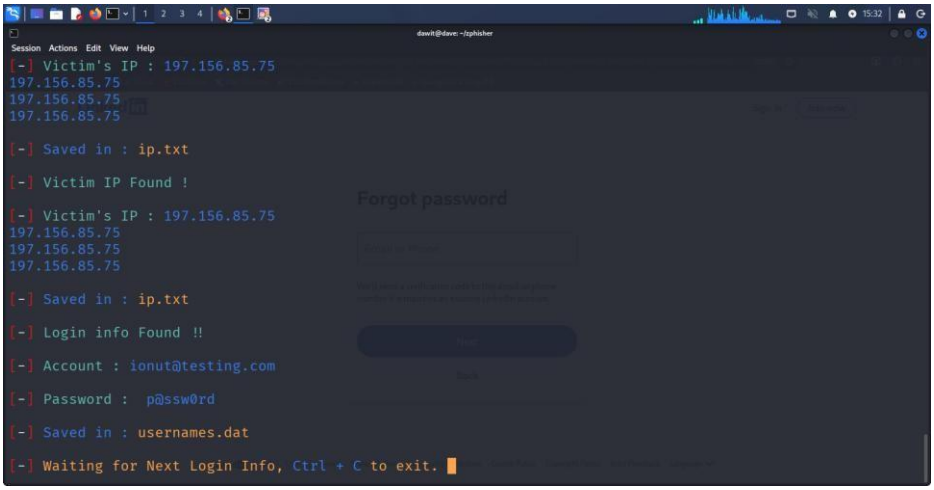
Zphisher template menu.



Tunneling option selected and generated URL displayed



: Phishing page rendered in Firefox at the generated URL



Captured credentials shown in the Zphisher terminal after test submission

Analysis Questions

Q1. How does Zphisher differ from SET in terms of templates?

SET's Site Cloner works by cloning any live website the operator points it at, so its "templates" are generated on demand rather than pre-built. Zphisher instead ships with 30+ pre-built, ready-to-use templates for specific well-known platforms (Instagram, Google, Microsoft, Netflix, LinkedIn, etc.), each already wired to a PHP credentialcapture backend. This makes Zphisher faster to deploy for common targets, while SET is more flexible for cloning an arbitrary or unlisted site.

Q2. What makes these templates convincing?

- They are built from pixel-accurate copies of the real platform's login HTML/CSS, including logos, fonts, and layout

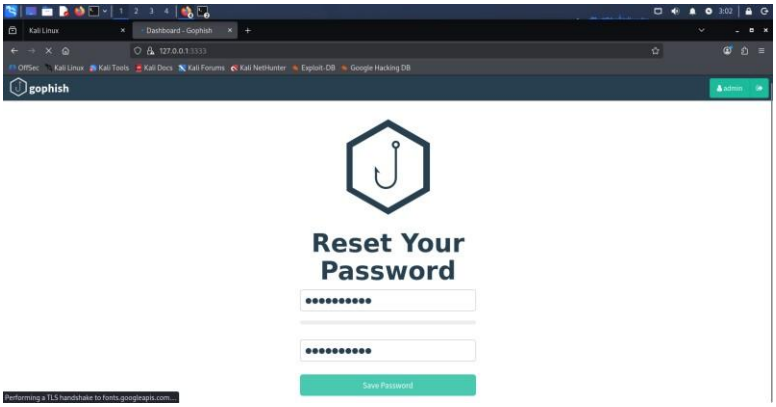
- Built-in tunneling options (e.g., Cloudflare) can provide a valid HTTPS certificate and a plausible-looking subdomain, removing the "Not Secure" warning that flagged the SET exercise
- The forms behave like the real site (field validation, "Forgot password" links, "Sign in with Google" buttons) even though the buttons are cosmetic

Q3. What defensive measures could detect these pages?

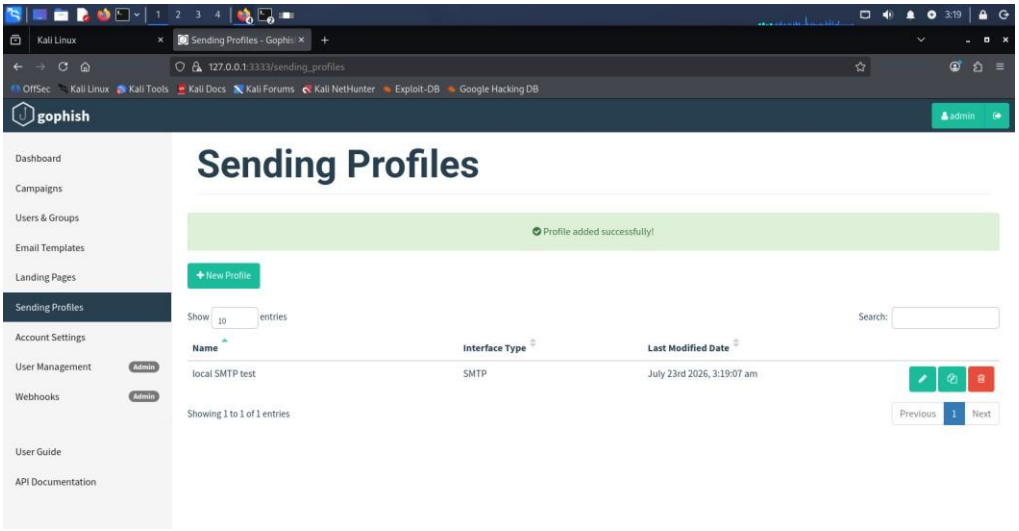
- Domain reputation/DNS filtering that flags newly registered or non-corporate domains (e.g., *.trycloudflare.com)
- Browser phishing-protection lists (e.g., Google Safe Browsing) that blocklist known phishing kit signatures
- Email security gateways with link-rewriting/sandboxing that follow the link before delivery
- User awareness: checking the actual domain, not just branding or the padlock icon
- Password managers that refuse to auto-fill credentials because the domain does not match the saved entry

Exercise 3: Professional Phishing Campaigns with GoPhish

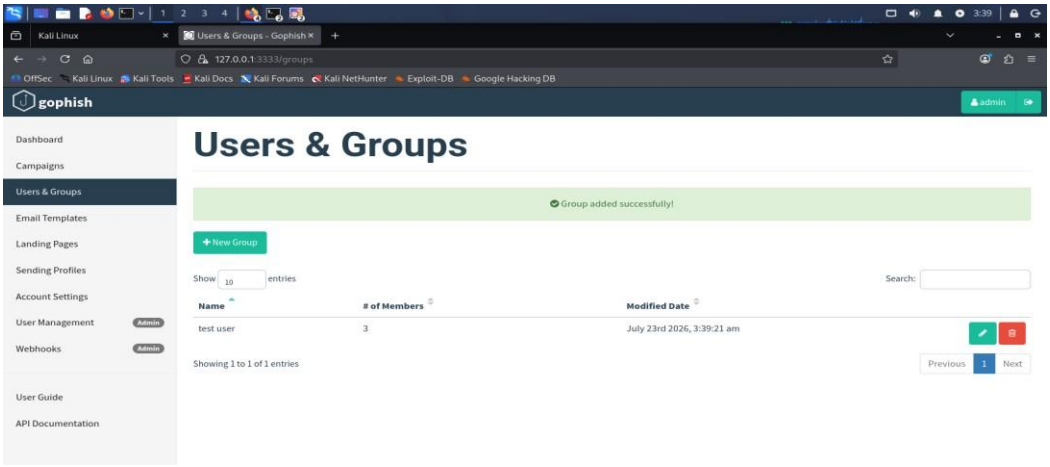
Objective: Set up a complete phishing campaign management system



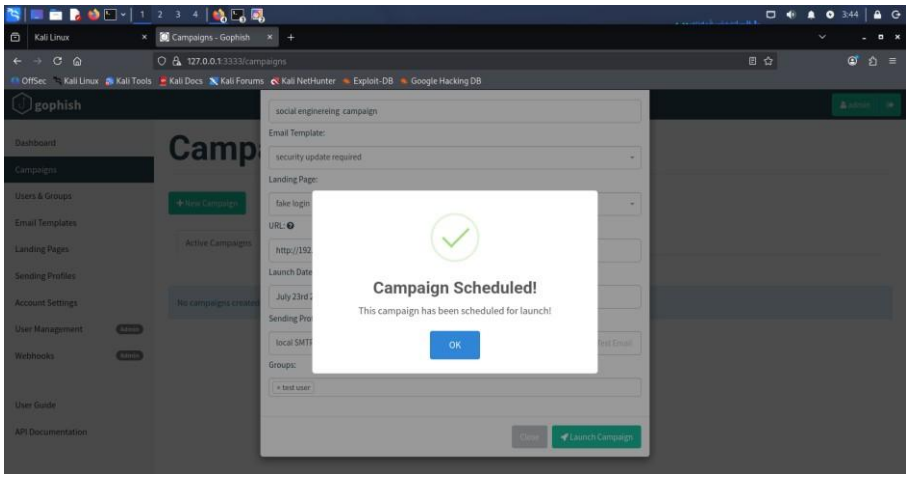
GoPhish login screen and dashboard after first login



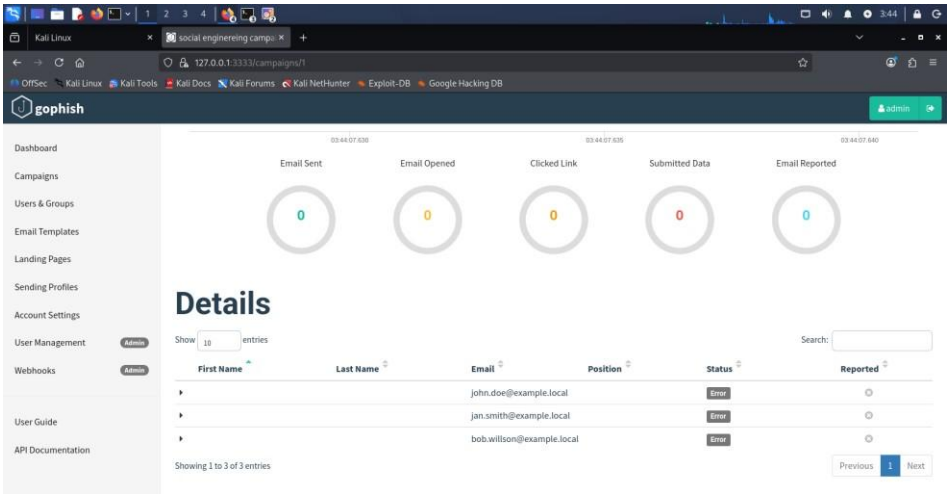
Sending Profile configuration

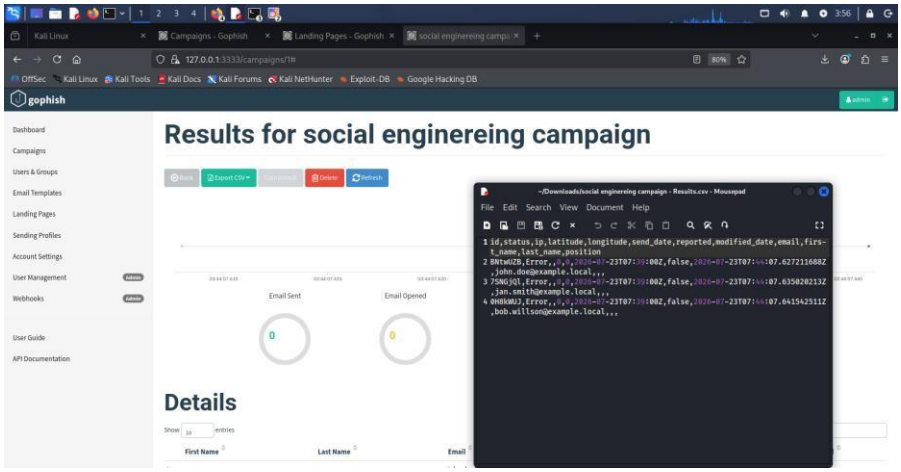


Test Users group creation



: Campaign creation form





Exported campaign results

Reflection Questions

Q1. How does GoPhish provide better campaign management than SET or Zphisher?

SET and Zphisher are single-target, single-session tools focused on getting one phishing page online quickly. GoPhish is a full campaign management platform: it tracks multiple recipients as a defined group, times each stage of interaction (sent, opened, clicked, submitted), pairs a specific email template with a specific landing page, and stores everything in a queryable dashboard with exportable results. This turns a one-off proof of concept into a repeatable, measurable exercise — which is exactly why organizations use GoPhish for authorized internal phishing simulations rather than SET or Zphisher.

Q2. What metrics are most valuable for assessing phishing effectiveness?

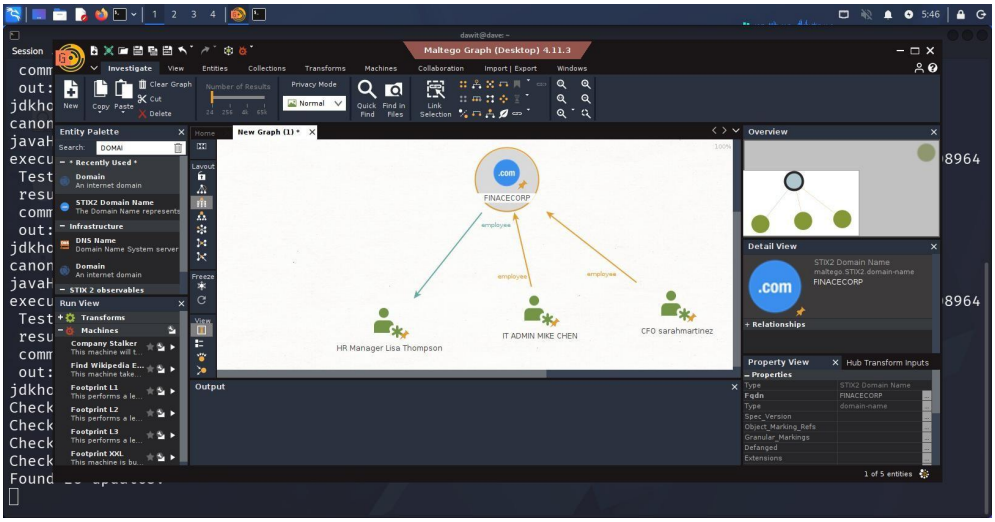
- Open rate (email opened) — measures subject-line/sender credibility
- Click-through rate (link clicked) — measures how convincing the pretext and email body are
- Submission rate (credentials/data submitted) — measures how convincing the landing page is and the ultimate risk exposure
- Report rate (employees who flagged the email as suspicious) — measures security-awareness culture, arguably the most important defensive metric
- Time-to-click / time-to-report — how quickly employees interacted with or reported the message

Q3. How could an organization use this for security awareness training?

An organization can run scheduled, authorized GoPhish campaigns against its own staff, then use the per-employee results to deliver immediate, targeted micro-training to anyone who clicked or submitted data, while tracking rate-of-improvement over successive campaigns as a KPI for the security-awareness program. Aggregated, anonymized results can also help prioritize which departments or roles need additional training.

Exercise 4: OSINT Reconnaissance with Maltego

Objective: Use Maltego to perform reconnaissance on a fictional organization



Maltego graph with the Domain entity created

Analysis

Q1. How does visual relationship mapping aid reconnaissance?

A graph view lets an analyst (or attacker) see second- and third-order connections that would be easy to miss in a flat list — for example, which email addresses trace back to which domain, which domains share the same registrant or name servers, and which phone numbers or subdomains are linked to which entity. This makes it far faster to identify the most valuable pivot points (e.g., an admin's personal email reused on a company domain) than manually cross-referencing separate search results.

Q2. What information sources does Maltego aggregate?

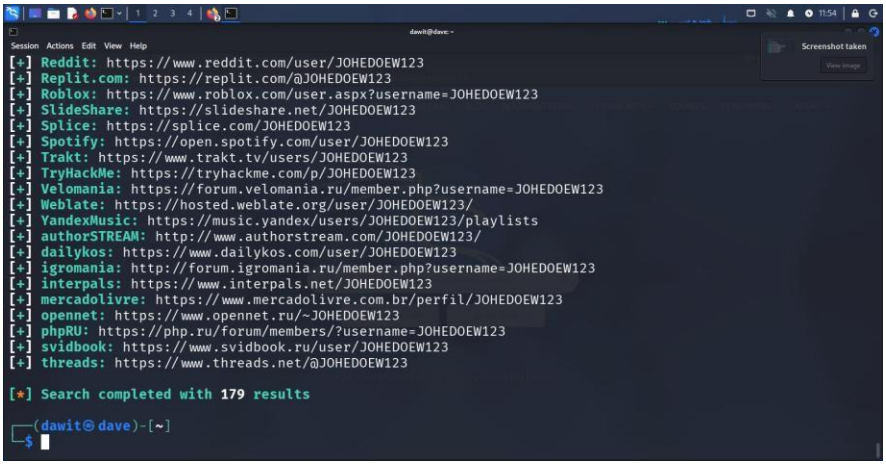
- WHOIS/registrar records (domain ownership, registrant contact details)
- DNS records (subdomains, mail servers, IP addresses, name servers)
- Search engines and public web content (email addresses, mentions, cached pages)
- Social media and people-search transforms (usernames, profiles, affiliations)
- Historical/archived snapshots of websites

Q3. How could attackers use this information for targeted phishing?

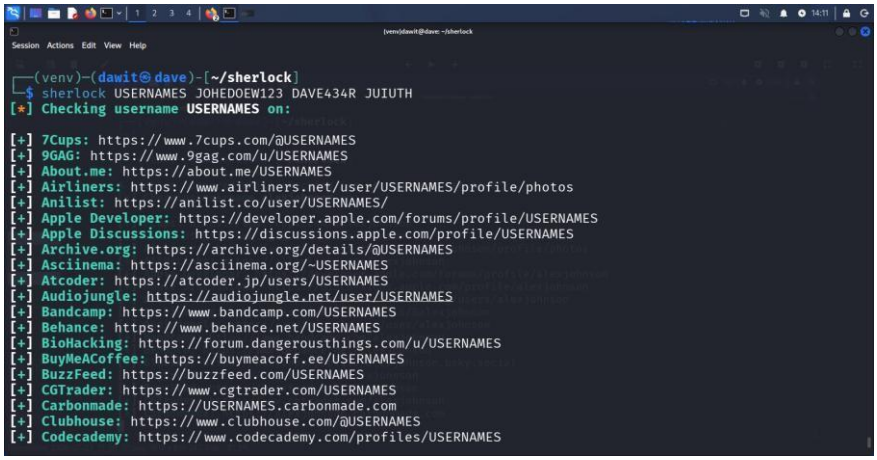
By combining an organization's email naming convention, employee names/roles, and technical infrastructure details (mail server, hosting provider), an attacker can craft a spear-phishing email that appears to come from a specific real colleague or vendor, references real internal systems, and is sent to the correct address format — all of which dramatically increases the credibility and success rate of the pretext compared to a generic phishing blast.

Exercise 5: Username Enumeration with Sherlock

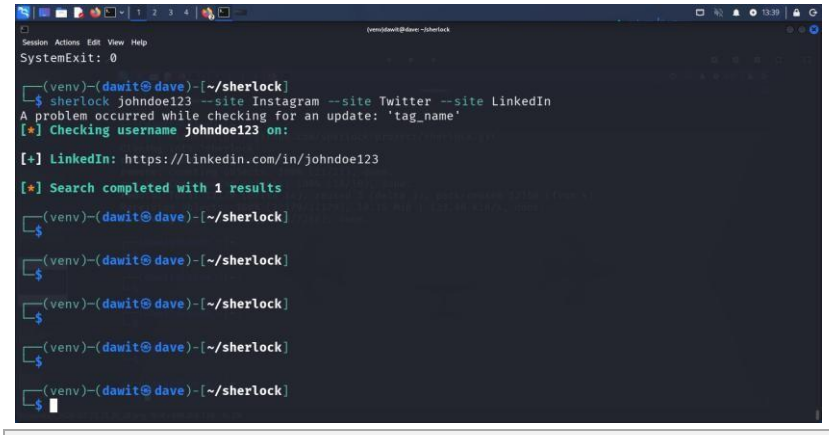
Objective: Discover social media presence across multiple platforms



Results of searching a single fictional username

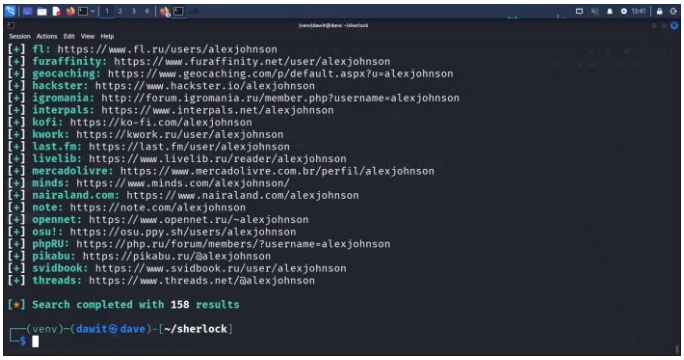


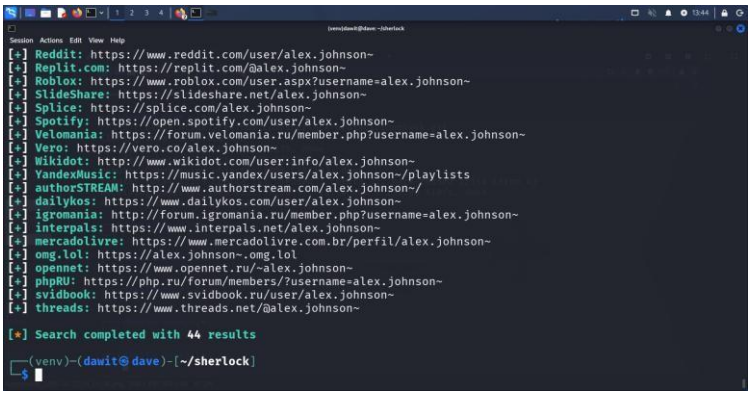
Results of searching many fictional username



search results limited to specific sites

Reconnaissance Scenario Notes





Username variations tested

Discussion Points

Q1. How much information can be gathered from a username alone?

A surprising amount. A single reused username can reveal which platforms someone has accounts on, which in turn can expose a profile photo, bio, employer, location, interests, linked email or website, and posting history. Cross-referencing several matched profiles often lets an attacker build a fairly complete picture of someone's identity, habits, and social circle without ever needing a password.

Q2. What privacy settings help protect against this reconnaissance?

- Using different, non-correlated usernames across unrelated platforms
- Setting profiles to private and limiting what is visible to non-connections
- Removing or restricting profile photos, bios, and location data from public view
- Disabling public account-recovery hints (e.g., "is this your email" lookups)
- Periodically auditing your own digital footprint with tools like Sherlock to see what is discoverable

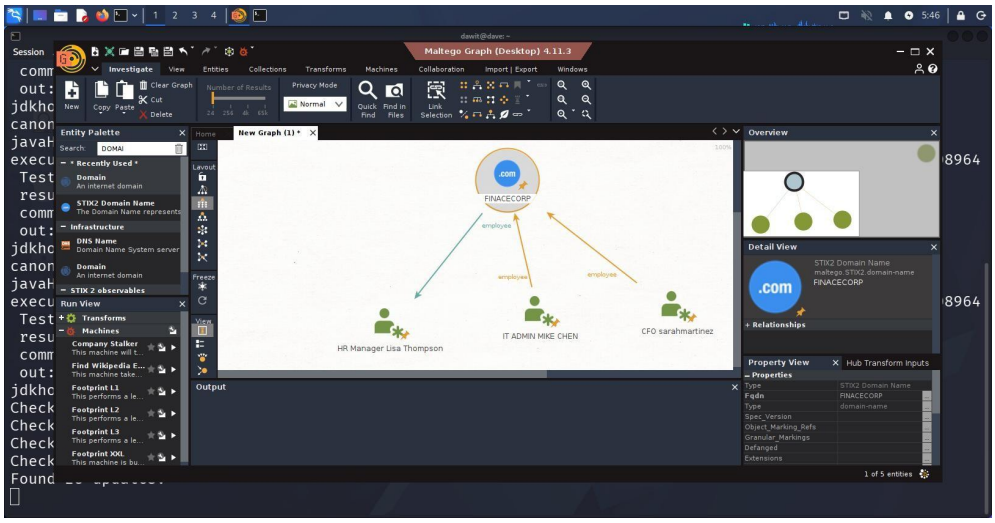
Q3. How do attackers use this information for targeted attacks?

Attackers use enumerated accounts to build a pretexting profile — confirming a target's employer, job title, interests, or personal relationships — which is then woven into a spear-phishing email, a fake connection request, or a social-engineering phone call (vishing) that feels personally relevant and therefore more trustworthy. It can also reveal password-reset attack surface (which platforms to target for account takeover) and help an attacker guess security-question answers from publicly shared personal details.

Exercise 6: Integrated Attack Scenario

Objective: Combine reconnaissance and phishing techniques in a simulated attack chain against fictional employees of "FinanceCorp"

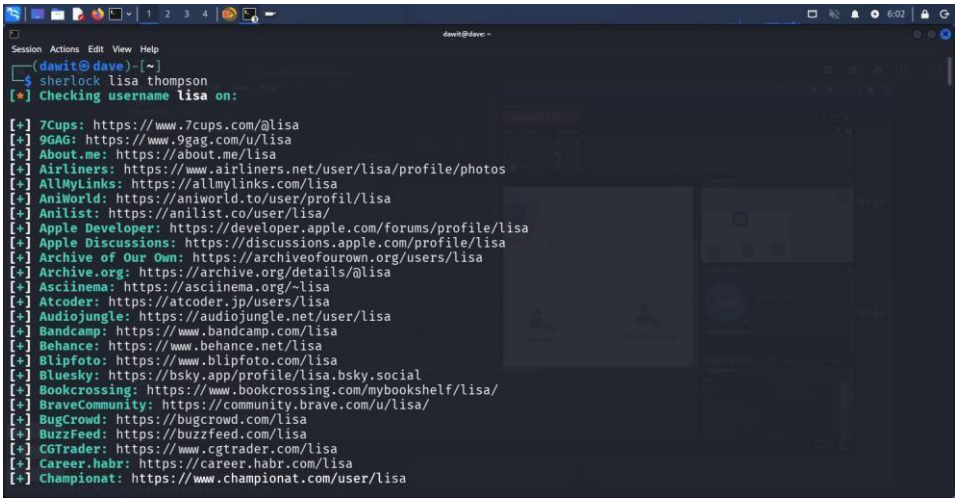
1. Reconnaissance Phase



Maltego graph mapping fictional FinanceCorp entities (Company, Employees, Domain: financecorp.local

Sherlock searches for fictional employee usernames

2. Intelligence Gathering — Findings Log

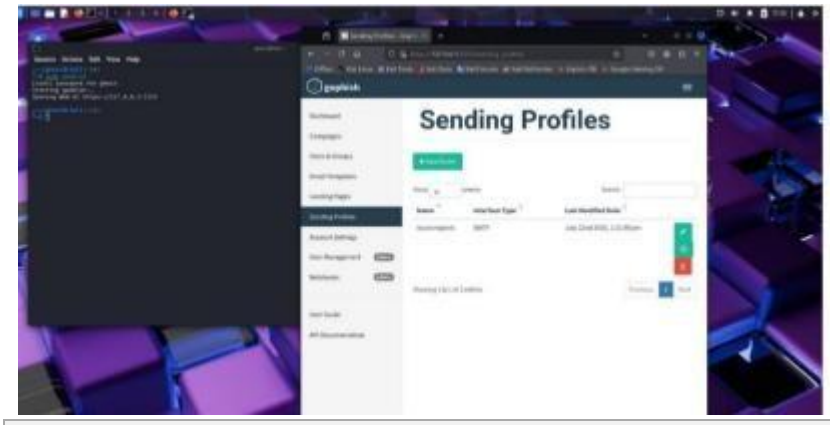


findings: employee names

3. Pretext Development

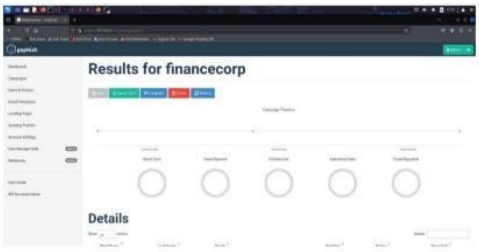
CFO sarah mentez beign affected because of role

4. Attack Deployment



GoPhish campaign targeting the fictional Test Users group

5. Execution and Analysis

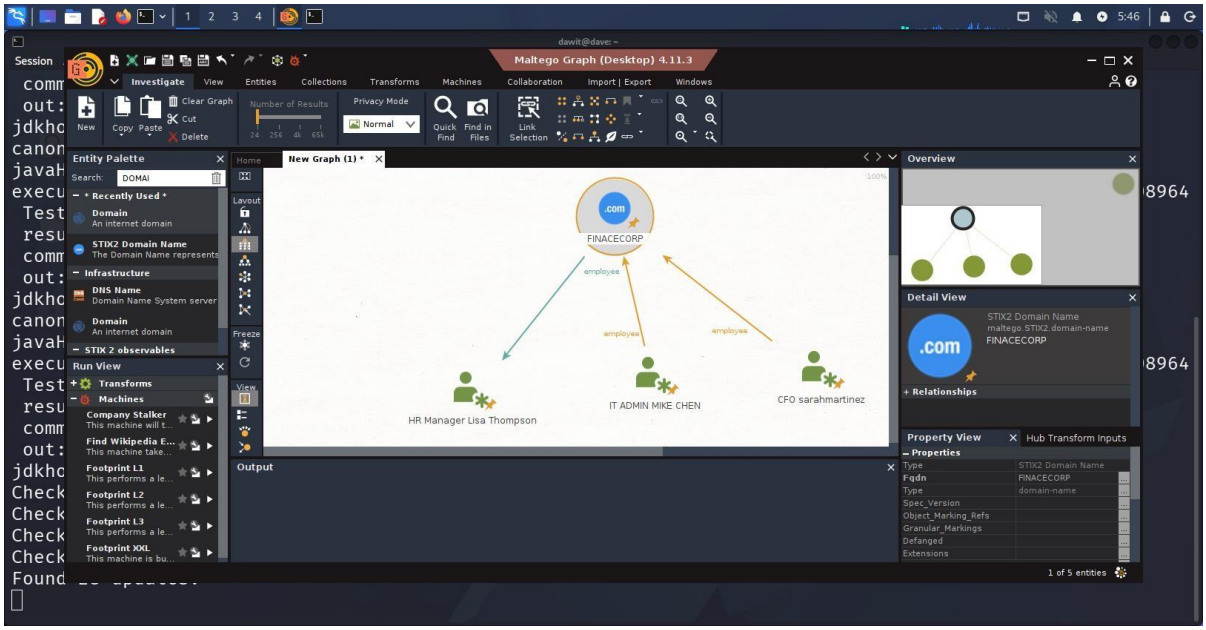


Campaign results after simulated employee interaction

6. Report Generation

Exercise 6 Deliverable: Integrated Attack Chain Report

Reconnaissance Findings

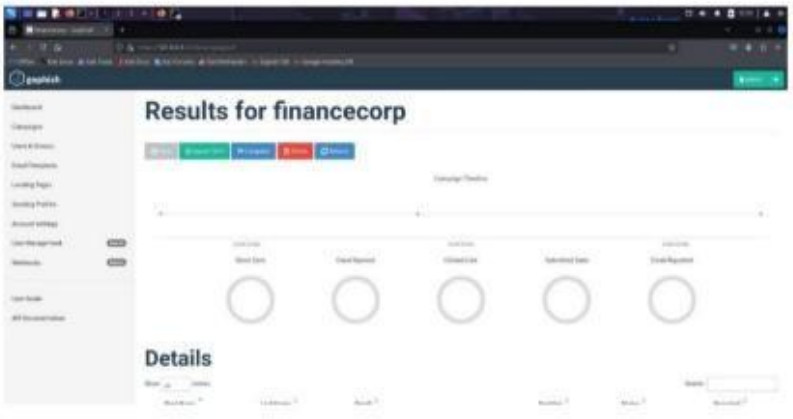


fictional employee names/roles, and organizational hierarchy discovered via Maltego

Attack Methodology

The simulated attack chain followed the classic social-engineering kill chain: (1) OSINT reconnaissance using Maltego to map the fictional organization's domain and personnel, and Sherlock to enumerate any associated usernames; (2) intelligence consolidation into an employee/role/email-format profile; (3) pretext development tailored to the least technical role identified (an IT password-reset notice); (4) deployment via a GoPhish campaign combining a spoofed IT-department email template with a cloned internallooking password-reset landing page; and (5) execution against the fictional test group with results captured in the GoPhish dashboard.

Success Metrics



campaign's simulated open rate / click rate / submission rate

Defensive Countermeasures

- Security awareness training focused on IT/password-reset themed phishing
- MFA enforcement so a captured password alone is insufficient for account access
- Email authentication controls (DMARC/SPF/DKIM) to reduce spoofed internal sender addresses
- A clear, blame-free reporting channel so employees flag suspicious IT-themed emails quickly
- Reducing the organization's public OSINT footprint (employee directories, emailformat disclosure)

Defensive Measures and Best Practices

For Individuals

- Verify URLs before clicking: Hover over links to see the actual destination. Check the full domain name, not just the presence of HTTPS.
- Enable Multi-Factor Authentication (MFA): Even if credentials are stolen, MFA provides a critical second layer of defense.
- Use a password manager: Password managers can detect phishing sites because they won't auto-fill credentials on fake domains.

- Be skeptical of urgency: Phishing emails create artificial urgency ('Your account will be closed!', 'Verify now!'). Take time to verify legitimacy.
- Verify through separate channels: If you receive a suspicious email claiming to be from your bank, call the bank directly using the number on their official website.
- Limit your digital footprint: The less personal information available online, the harder it is for attackers to target you with convincing pretexts.

For Organizations

- Conduct regular security awareness training: Educate employees about phishing, social engineering, and safe computing practices.
- Run phishing simulations: Use tools like GoPhish to test employee awareness and identify those who need additional training.
- Implement email security controls: Deploy DMARC, SPF, and DKIM to prevent email spoofing. Use email gateways with link analysis and sandboxing.
- Enforce MFA organization-wide: Require multi-factor authentication for all accounts, especially privileged accounts.
- Monitor for brand impersonation: Use services that detect phishing sites impersonating your organization.
- Establish clear reporting procedures: Make it easy for employees to report suspicious emails without fear of blame.
- Limit public information: Review what organizational and employee information is publicly available. Attackers use this for reconnaissance.

Lab Questions and Discussion

Technical Questions

1. What are the key differences between SET, Zphisher, and GoPhish? When would you use each?

- SET is a general-purpose social-engineering framework that can clone any live site on demand and covers multiple attack vectors beyond phishing (payload/listener generation, mass mailer, PowerShell attack vectors). Best for quick, flexible, single-target proof-of-concept demonstrations.

- Zphisher is a purpose-built phishing tool with 30+ pre-made templates for popular platforms and built-in tunneling (including HTTPS via Cloudflare). Best when you need a fast, realistic-looking clone of a specific well-known service.
- GoPhish is a campaign management platform, not just a page cloner — it manages sending profiles, templates, landing pages, target groups, and detailed analytics across a full campaign lifecycle. Best for authorized, organization-wide phishing simulations where tracking and reporting matter.

2. How does the credential harvesting process work technically? Trace the path from user input to attacker capture.

1. The attacker hosts a cloned HTML login form on a local web server (Apache in SET, PHP's built-in server in Zphisher, or GoPhish's landing-page server).
2. The victim visits the phishing URL and is served the cloned page, visually identical to the legitimate site.
3. The victim enters their username and password into the HTML form fields.
4. On clicking "Submit", the browser sends an HTTP POST request containing the form data to the attacker's server instead of the real service.
5. A server-side script (a PHP page in Zphisher/GoPhish, or SET's built-in listener) intercepts the POST request, parses the submitted fields, and writes them to a log file or database on the attacker's machine (e.g., ~/.zphisher/auth/, SET's reports directory, or the GoPhish database).
6. The victim is typically redirected to the real website afterward so nothing appears to have gone wrong from their perspective.
7. The attacker later reviews the captured log/database to retrieve the harvested credentials.

3. What network traffic would a security analyst see during a phishing attack? What IOCs should they look for?

- DNS queries or HTTP requests to a newly registered, unusual, or non-corporate domain that resembles a known brand
- HTTP (not HTTPS) traffic to a login-style page, or HTTPS traffic to a domain with a mismatched/suspicious certificate
- Outbound POST requests carrying form data (username/password fields) to an external or unfamiliar host

- Traffic to known tunneling infrastructure (e.g., *.trycloudflare.com, ngrok domains) associated with phishing kits
- Email gateway logs showing a link-rewritten URL that redirects through multiple hops before reaching the landing page

4. How do modern browsers and email clients attempt to detect phishing? What features did you observe?

Browsers use services like Google Safe Browsing to flag known-malicious URLs and will display a "Deceptive site ahead" warning; they also show "Not Secure" for non-HTTPS pages, which was clearly visible in the SET exercise. Email clients use spam/phishing filters based on sender reputation, SPF/DKIM/DMARC authentication results, and content analysis (urgency language, mismatched display names, embedded links) to flag or quarantine suspicious messages. In this lab, the SET-hosted page was flagged by the browser as "Not Secure" due to the absence of a valid certificate, while a Zphisher page tunneled through a service offering a trusted certificate did not trigger that particular warning.

5. What role does HTTPS play in phishing attacks? How do attackers handle certificate warnings?

HTTPS only guarantees an encrypted connection to whatever domain is in the address bar — it says nothing about whether that domain is legitimate. Attackers increasingly obtain free, automated certificates (e.g., via Let's Encrypt, or through tunneling services like Cloudflare/ngrok that provide HTTPS by default) so their phishing pages display a valid padlock and avoid triggering "Not Secure" warnings, defeating the old advice of "look for the padlock." The only reliable check remains verifying the actual domain name itself, not just the presence of encryption.

Strategic Questions

6. Based on your reconnaissance, what types of information are most valuable for crafting targeted phishing campaigns?

- Organizational email naming convention (firstname.lastname@domain) — enables believable "from" and "to" addresses
- Employee names, job titles, and reporting structure — enables convincing impersonation of a manager, IT staff, or executive
- Technology/vendor details (e.g., which email or file-sharing platform is used) — enables a believable pretext template

- Recent events, projects, or public announcements — adds specific, current-feeling detail that increases credibility
- Personal social media details of individual employees — enables highly tailored spear-phishing or vishing pretexts

7. How would you design a security awareness program to counter the techniques you practiced?

The program would combine recurring (e.g., quarterly) GoPhish-style simulated phishing campaigns modeled on real techniques (credential harvesting pages, urgency-themed IT/HR pretexts) with short, role-specific micro-training triggered immediately after an employee clicks or submits data. It would include a one-click "Report Phishing" button in the email client, track click/report rates over time as the core KPI, and supplement simulations with brief live sessions on verifying URLs, recognizing urgency tactics, and using out-of-band verification for sensitive requests.

8. What organizational policies and technical controls can reduce phishing effectiveness?

- Policy: mandatory MFA for all accounts, especially privileged ones; a documented incident-reporting process without blame; least-privilege access so a single compromised account has limited blast radius
- Technical: DMARC/SPF/DKIM enforcement, email gateway link sandboxing, DNS filtering, endpoint detection and response (EDR), and browser isolation for suspicious links
- Combined: regular simulated phishing tied to policy-driven follow-up training, and network segmentation limiting lateral movement even if a phish succeeds

9. How do you balance the need for accessible systems with security requirements?

This is fundamentally a risk-based trade-off rather than an either/or choice. Usabilitypreserving controls (single sign-on with MFA, password managers, risk-based/adaptive authentication that only adds friction for unusual logins) let organizations tighten security without materially slowing down legitimate users, while the highest-friction controls (e.g., mandatory hardware tokens, network segmentation) are reserved for the highest-risk systems and accounts. The goal is proportionality: security controls scaled to the sensitivity of the system, not a uniform maximum-friction policy applied everywhere.

10. What metrics should an organization track to measure their resilience against social engineering?

- Simulated-phishing click rate and submission rate over time (trend, not a single snapshot)
- Reporting rate — the percentage of employees who correctly flag a suspicious email
- Time-to-report a real or simulated phishing email ● MFA adoption/enforcement rate across accounts
- Number of real phishing incidents reaching production impact (credential compromise, financial loss) per period

Ethical Questions

11. Where is the line between security testing and malicious activity? What factors determine this?

The determining factors are authorization, scope, and intent. Legitimate security testing has explicit written permission from the system/data owner, is bounded to an agreed scope (which systems, which techniques, which time window), and is conducted to identify and report weaknesses so they can be fixed. The exact same technical actions performed without that authorization — or performed with intent to steal, damage, or extort — are malicious activity, regardless of the operator's skill level or stated good intentions.

12. How do you ensure informed consent when conducting phishing simulations for an organization?

Informed consent is established at the organizational level through a signed engagement/authorization letter from executive leadership or the system owner (not individual employees, since the simulation's validity depends on employees not knowing it is a test), a clearly defined scope and rules of engagement, and typically involvement of HR/Legal to ensure the exercise complies with employment and privacy policies. Employees are usually informed afterward, and in aggregate, that phishing simulations occur as part of the security program, with individual results used constructively (training) rather than punitively.

13. What are the psychological impacts of phishing simulations on employees? How should organizations address this?

Employees who fall for a simulation can experience embarrassment, anxiety, or a feeling of being "tricked" by their own employer, which — if handled poorly — can erode trust and discourage future openness about mistakes. Organizations should address this by

framing simulations explicitly as no-blame learning exercises, delivering immediate supportive (not punitive) micro-training rather than public callouts, keeping individual results confidential, and communicating clearly why the program exists and how it protects both the employee and the organization.

14. Should security researchers be allowed to create and share phishing tools? What are the arguments on both sides?

- For: Open tools like SET, Zphisher, and GoPhish let defenders learn attacker techniques firsthand, build realistic detection and training programs, and lower the barrier to entry for security education and authorized red-teaming; the same tools are often built and used by legitimate consultancies performing paid, authorized assessments.
- Against: The same accessibility that helps defenders also lowers the technical bar for less sophisticated criminals, and once published, tool authors have no control over who downloads and misuses them; some argue sensitive attack tooling should be shared through more restricted, vetted channels (responsible/limited disclosure) rather than fully public repositories.
- In practice, most of the security community accepts open dual-use tooling as net positive for defense, provided it is paired with clear "authorized use only" licensing, and use in the field remains governed by law (e.g., the CFAA) regardless of the tool's availability.

Comprehensive Lab Assessment Questions

Section 1: Technical Understanding

1. Explain the technical process of credential harvesting. (5 points)

When a victim clicks a phishing link, their browser sends an HTTP GET request to the attacker-controlled server, which responds with a cloned HTML login page (typically a near-exact copy of the target's real front-end markup and styling, with the original form's "action" attribute rewritten to point back to the attacker's server instead of the real one). The victim fills in the visible username/password fields and clicks submit, which fires an HTTP POST request containing that form data to the attacker's web server. A lightweight backend component — a PHP script in Zphisher/GoPhish, or SET's built-in Python listener — receives that POST request, parses the field values, and appends them as plaintext to a log file (or database record, in GoPhish's case) on the attacker's machine, timestamped and often including the victim's source IP. The victim is then

typically redirected to the real service's actual login page (or shown a generic error), so nothing appears amiss, while the attacker later reviews the log/database to retrieve the harvested credentials.

2. Compare and contrast SET, Zphisher, and GoPhish. (5 points)

SET is the most general-purpose of the three: it can clone essentially any live website on the fly and bundles multiple attack vectors beyond web cloning (payload generation, mass mailer, PowerShell attacks), making it flexible but manual and single-target. Zphisher trades that flexibility for speed and polish — it ships 30+ ready-made templates of popular platforms with built-in HTTPS tunneling, making it ideal for quickly standing up a convincing, secure-looking clone of a well-known service. GoPhish is the only one built as a full campaign platform rather than a page generator: it manages sending profiles, templates, landing pages, recipient groups, and time-stamped analytics (sent/opened/clicked/submitted) through a persistent dashboard. In practice: SET suits ad-hoc demonstrations against an arbitrary site; Zphisher suits a fast, convincing singletarget proof of concept; GoPhish suits an authorized, trackable, organization-wide phishing assessment where measurable results and reporting matter.

3. Explain the role of SSL/TLS in phishing attacks. (5 points)

SSL/TLS (shown as HTTPS and the padlock icon) only certifies that traffic between the browser and whatever domain is in the address bar is encrypted in transit — it makes no claim about whether that domain is trustworthy or belongs to who it claims to be. For years users were taught "look for the padlock," but automated certificate authorities like Let's Encrypt now issue free, domain-validated certificates in minutes to anyone who controls a domain, including a freshly registered look-alike domain built purely for phishing. This is a double-edged sword: it helps security broadly by encrypting the web by default, but it hinders the old heuristic by giving attackers the same trust signal as legitimate sites, meaning the actual domain name — not the presence of HTTPS — is now the only reliable indicator a user can check.

4. What are indicators of compromise (IOCs) for phishing attacks? (5 points)

- Network: DNS lookups or HTTP/HTTPS connections to a newly registered, unfamiliar, or brand-look-alike domain
- Network: outbound POST requests carrying form-field data (username/password) to an external host shortly after an email link was clicked
- Log entries: web/email gateway logs showing a rewritten or redirected link chain terminating at a known phishing-kit hosting pattern (e.g., free tunneling subdomains)

- System artifacts: unexpected browser-saved-password prompts on an unfamiliar domain, or a password manager declining to auto-fill on a page it doesn't recognize
- Authentication logs: a successful login immediately followed by an unusual login from a new location/IP shortly after, suggesting the harvested credential was reused by the attacker

Section 2: OSINT and Reconnaissance

5. Describe the OSINT kill chain.

The typical phases are: (1) Passive reconnaissance — gathering information from public sources without touching the target directly (WHOIS, DNS records, search engines, social media); (2) Enumeration — turning broad findings into structured, specific data points, such as an organizational chart, employee list, or email naming convention (this lab's Maltego and Sherlock exercises); (3) Correlation/analysis — cross-referencing data points across sources to identify high-value pivots, such as a personal email reused on a corporate account, or an employee's role making them a good pretexting target; (4) Weaponization — using the consolidated intelligence to craft a tailored pretext (a spearphishing email, a vishing script); and (5) Delivery/exploitation — deploying the crafted attack against the identified target. Each phase builds on the last by narrowing a wide set of public information into an increasingly specific, actionable attack plan.

6. What types of transformations did you run in Maltego?

- Email addresses from Domain — reveals email addresses publicly associated with a domain, useful for confirming the organization's email format and identifying real point-of-contact addresses
- Domain Name System (DNS) lookup — reveals mail servers, name servers, and subdomains, useful for mapping technical infrastructure that could be spoofed or targeted
- To Details (Whois) — reveals registrant/administrative contact details, useful for identifying who manages the domain and potential impersonation targets
- Search Web / Explore Historical Snapshots — reveals cached or archived content and public mentions, useful for finding old employee names, org-chart pages, or documents no longer linked from the live site

Attackers could weaponize this information by building a believable spear-phishing pretext (correct email format, real names, real technical vendor names) or by targeting exposed infrastructure (e.g., an outdated mail server) directly.

7. Analyze the privacy implications of username reuse.

Reusing the same username across platforms lets a tool like Sherlock link accounts that the user may consider unrelated or private, turning isolated fragments of information into a composite profile — for example, a forum post revealing a hobby, a fitness app revealing a general location, and a professional network revealing an employer. An attacker piecing this together can build a far more convincing pretext than any single platform's data would allow, and can also identify additional attack surface, such as which platforms to target for a password-reset or account-takeover attempt.

8. How can organizations reduce their OSINT footprint?

- Limit publicly listed employee directories, org charts, and email addresses on the corporate website to only what is operationally necessary
- Avoid a predictable, universally disclosed email-naming convention where possible, or monitor for its exposure
- Configure WHOIS privacy/proxy protection on all owned domains so registrant contact details are not directly exposed
- Provide employee guidance on limiting work-identifying details in personal social media profiles
- Periodically run the same OSINT tools (Maltego, Sherlock, Google dorking) against the organization itself to see what an attacker would find, and remediate accordingly

Section 3: Attack Scenarios and Psychology

9. Design a targeted spear phishing campaign.

Target: a fictional junior accounts-payable employee at "FinanceCorp." Reconnaissance phase: use Maltego to confirm the domain's email format and identify the CFO's name and title, and Sherlock/LinkedIn-style searches to confirm the target's role. Pretext development: craft an email impersonating the CFO, referencing a real-sounding recent event (e.g., "quarter-end vendor payment reconciliation"), with urgent tone and a request to review an "updated invoice" via a link. Payload delivery: the link points to a GoPhish-hosted landing page cloned to resemble the company's internal documentportal or SSO login, capturing submitted credentials. Expected outcome: given the urgency, authority (CFO impersonation), and role-appropriate content, the target is likely to click and may enter their SSO credentials, which — in a real attack — would grant the attacker access to the target's mailbox or internal systems for further lateral pretexting or financial fraud.

10. What psychological principles make phishing effective?

- Authority: impersonating a boss, IT department, or executive leverages the target's instinct to comply with a superior's request without question (e.g., the "IT Department password reset" pretext used in Exercise 6)
- Urgency: phrases like "your account will be suspended" or "action required within 24 hours" push the target to act quickly rather than pause and verify, reducing critical scrutiny
- Social proof/familiarity: an email appearing to come from a known colleague, or referencing a real internal project, exploits the target's trust in familiar names and context

Real-world examples include CEO-fraud ("business email compromise") wire-transfer scams that combine authority and urgency, and fake "shared document" notifications that combine familiarity (a known collaborator's name) with a routine, low-suspicion action (clicking to view a file).

11. Why do attackers redirect victims to real sites after credential theft?

Redirecting the victim to the legitimate site immediately after credential submission is a deception technique that hides the attack: the victim sees the real, familiar site load normally (sometimes even landing them already logged in, or prompting a normallooking re-login) and has no visible reason to suspect anything went wrong. This delays detection and reporting — the longer a victim believes nothing happened, the longer the attacker has to use the stolen credentials before the compromise is discovered and the password is changed.

12. Analyze a recent real-world phishing campaign.

One widely reported case is the 2023 MGM Resorts breach, attributed to the Scattered Spider group, which began with a social-engineering/vishing attack against MGM's IT help desk rather than a traditional email phish: attackers impersonated an employee over the phone to have the help desk reset multi-factor authentication and gain initial access. The attack succeeded largely because help-desk verification procedures relied on easily obtainable personal details (an OSINT weakness similar to this lab's Maltego/Sherlock exercises) rather than a stronger out-of-band verification step. Stronger identity-verification protocols for help-desk password/MFA resets — such as callback verification through a pre-registered number, or requiring in-person or video confirmation for high-privilege account changes — could plausibly have prevented or slowed the initial access in this case. (Note: publicly reported details of this incident

have varied across sources; specifics should be verified against current reporting before citing this case in a formal deliverable.)

Section 4: Defense and Mitigation

13. Design a security awareness training program.

Key topics: recognizing urgency/authority-based pretexts, verifying links and sender domains, safe handling of unexpected attachments, MFA and password-manager hygiene, and how/where to report suspicious messages. Frequency: brief mandatory onboarding training, followed by quarterly refresher micro-modules and unannounced simulated-phishing tests throughout the year. Delivery methods: short interactive elearning modules, periodic live/virtual sessions for high-risk roles (finance, HR, executives), and just-in-time micro-training triggered automatically when an employee clicks a simulated phishing link. Success metrics: trending decline in simulated-phishing click/submission rates, trending increase in report rates, reduced average time-toreport, and a year-over-year reduction in real phishing-related incidents.

14. Evaluate technical controls against phishing.

- Email filtering (SPF/DKIM/DMARC enforcement, link sandboxing): highly effective as a first line of defense since it blocks or flags a large share of phishing emails before they reach the inbox, but cannot catch every novel or well-crafted message
- DNS filtering: effective at blocking connections to already-known-malicious domains, but limited against brand-new phishing infrastructure not yet on a blocklist
- Browser protection (Safe Browsing-style warnings): a useful last-line safety net for the end user, but relies on the site already being reported/catalogued as malicious
- EDR solutions: less about preventing the initial phish and more about detecting and containing what happens after a compromise (credential misuse, malware execution), making them a critical second layer rather than a phishing-specific control
- Network segmentation: does not prevent phishing itself but significantly limits the blast radius if a phishing attack succeeds, making it one of the most valuable overall risk-reduction controls even though it is not phishing-specific

Overall, no single control is sufficient; email filtering plus MFA plus segmentation together address the delivery, exploitation, and impact stages respectively.

15. How should organizations handle phishing incidents?

Immediate actions: isolate/disable the affected account or device, force a password reset and MFA re-registration, and preserve the phishing email/URL for analysis. Investigation steps: identify how many other employees received the same message, determine whether credentials were actually submitted or any malware executed, check authentication logs for suspicious post-incident logins, and assess what data or systems the affected account could access. Remediation: revoke any active sessions/tokens for the compromised account, patch or block the identified phishing infrastructure at the email/DNS gateway, notify affected stakeholders per applicable breach-notification obligations if data exposure occurred, and feed lessons learned back into targeted awareness training.

16. Discuss the ethics of defensive phishing simulations.

Argument that simulations are deceptive/distrust-building: employees did not consent individually to being deceived by their own employer, a failed simulation can feel humiliating or punitive, and repeated testing without transparency about its purpose can erode morale and trust in leadership. Argument in favor: unannounced testing is the only way to measure real-world susceptibility (employees who know a test is coming behave differently), the goal is protective rather than punitive, and the same deception techniques are what real attackers will use regardless of whether the organization tests for them. My reasoned view is that simulations are ethically defensible when governed by best practices: leadership/HR authorization rather than individual consent (since the test's validity requires surprise), a strictly non-punitive response to failures (training, not discipline or public shaming), transparent aggregate reporting on why and how the program operates, and confidentiality of individual results — turning the exercise into a learning tool rather than a trust-eroding trap.

Section 5: Legal and Ethical Considerations

17. Explain relevant cybersecurity laws.

Computer Fraud and Abuse Act (CFAA) — United States: criminalizes accessing a computer system "without authorization or exceeding authorized access," which directly covers unauthorized phishing, credential harvesting, and social engineering against systems the operator does not own or have explicit permission to test; penalties can include substantial fines and imprisonment, with severity scaling based on intent and damage caused. General Data Protection Regulation (GDPR) — European Union: governs the processing of personal data of EU residents, meaning unauthorized collection of personal data via phishing or OSINT reconnaissance (even without a traditional 'hack') can trigger GDPR liability; penalties can reach up to 4% of global

annual turnover or €20 million, whichever is higher, in addition to any separate criminal exposure under national law.

18. Define ethical boundaries in security testing.

The line between legitimate testing and malicious activity is defined primarily by authorization: legitimate testing occurs only against systems the tester owns or has explicit written permission to assess. Before conducting any social-engineering test, the following must be in place: a signed authorization/engagement letter from someone with the authority to grant it (system/business owner, not an individual employee), a clearly defined scope (which systems, techniques, and time window are in bounds), a disclosure and reporting plan for how findings will be communicated and to whom, and agreed rules of engagement covering what to do if a test causes unexpected impact (e.g., a real outage). Testing outside any of these boundaries — even with good intentions — crosses into unauthorized and potentially illegal activity.

19. Should security tools be publicly available?

Argument for open availability: tools like SET, Zphisher, and GoPhish lower the barrier to entry for security education, let smaller organizations run their own authorized assessments without expensive commercial licenses, and mirror the reality that real attackers already have access to (or can build) equivalent tooling, so defenders benefit more from open access than criminals gain. Argument against: the same low barrier to entry that helps students and defenders also equips less-skilled malicious actors who would otherwise lack the ability to build such tooling themselves, and public availability removes any control over downstream misuse. On balance, dual-use security tools are generally accepted as net-positive when openly licensed for authorized use, since defensive benefit (education, internal testing, red-team tooling) is broad while the marginal uplift given to already-motivated attackers is comparatively small — legal deterrence (e.g., the CFAA) is the more appropriate lever for controlling misuse than restricting tool availability.

20. Reflect on responsible disclosure.

If a real vulnerability is discovered during authorized testing, my responsibility is to report it promptly and privately to the system owner or the organization's designated security contact, providing enough technical detail for them to reproduce and remediate it, and to avoid exploiting it beyond what the engagement scope authorized or disclosing it publicly before a fix is available. This responsible-disclosure process matters to the security community because it gives vendors/owners a fair opportunity to patch the issue before attackers can learn of and exploit it, protects end users who would

otherwise be exposed during an unpatched window, and preserves the trust relationship that allows security researchers to keep doing this work — premature public disclosure can turn a defensive finding into an attacker's roadmap.

Safety Boundaries and Ethical Guidelines

Critical Reminders — Followed During This Lab **DO**

NOT:

- Send phishing emails to real people or external email addresses
- Attack any systems outside the VM environment
- Use real personal information in scenarios
- Test these techniques on any system not owned or explicitly authorized for testing
- Clone real company websites for anything other than education within the VM ● Access or attempt to access real social media accounts **DO:**
- Keep all activities contained within the Kali Linux VM
- Use only fictional names, companies, and email addresses
- Test phishing pages only on localhost or the VM's IP
- Delete all phishing infrastructure after lab completion
- Understand the legal consequences of unauthorized social engineering

Legal Notice

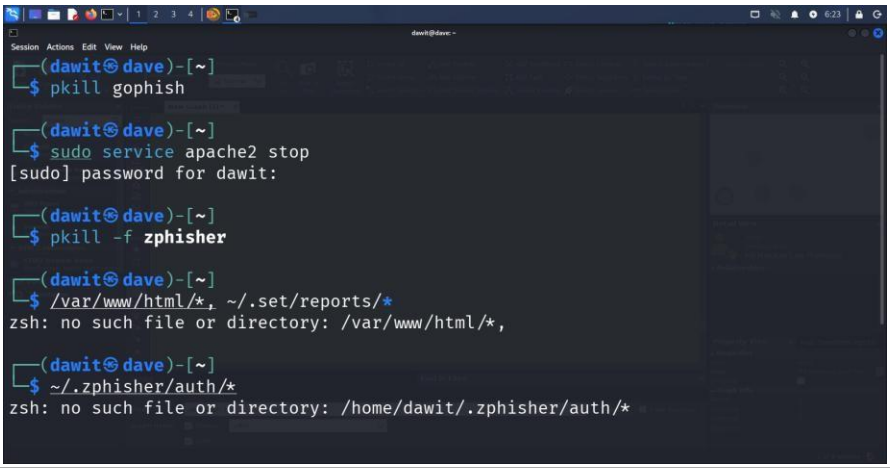
Unauthorized phishing, credential harvesting, and social engineering attacks are illegal under the Computer Fraud and Abuse Act (CFAA) in the United States, the General Data Protection Regulation (GDPR) in the European Union, and similar laws in virtually every jurisdiction worldwide. Penalties may include criminal prosecution, substantial fines, imprisonment, civil liability, and revocation of professional certifications.

All activities in this lab were confined to an isolated Kali Linux virtual machine using fictional data, in accordance with the safety boundaries above.

Cleanup Confirmation

The following cleanup steps were performed after completing the lab exercises:

- Stopped GoPhish (pkill gophish)
- Stopped Apache/SET listener (sudo service apache2 stop)
- Stopped any running Zphisher instances (pkill -f zphisher)
- Removed captured SET logs and reports (/var/www/html/*, ~/.set/reports/*)
- Removed Zphisher captured data (~/.zphisher/auth/*)

- Reset the GoPhish database (gophish.db)
- 

Terminal output confirming cleanup commands were executed

END